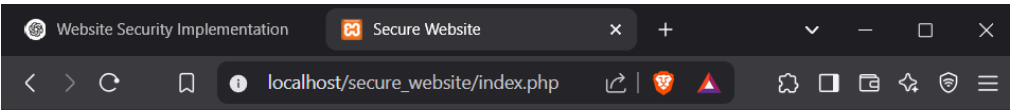


Implementing basic security measures

Basic Website:

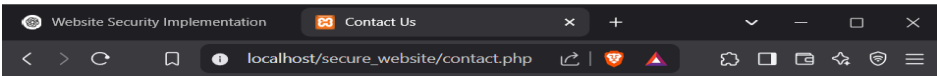


Welcome to My Secure Website

This is a simple PHP website with basic security measures.

[Go to Contact Page](#)

1. Prevent Cross-Site Scripting (XSS)



Contact Us

[Back to Home](#)

Before

After

process.php

C:\xampp\htdocs\secure_website> process.php

```
1 <?php
2 if ($_SERVER["REQUEST_METHOD"] == "POST") {
3     $name = $_POST['name'];
4     $message = $_POST['message'];
5
6     echo "<h2>Message Received</h2>";
7     echo "<p><strong>Name:</strong> $name</p>";
8     echo "<p><strong>Message:</strong> $message</p>";
9 }
10 ?>
11 <a href='contact.php'>Go Back</a>
12
```

Injecting script

localhost/secure_website/process.php

localhost says
Hacked!

Message Received

Name:
Message: Hii
[Go Back](#)

process.php

C:\xampp\htdocs\secure_website> process.php

```
1 <?php
2 if ($_SERVER["REQUEST_METHOD"] == "POST") {
3     $name = htmlspecialchars($_POST['name'], ENT_QUOTES, 'UTF-8');
4     $message = htmlspecialchars($_POST['message'], ENT_QUOTES, 'UTF-8');
5
6     echo "<h2>Message Received</h2>";
7     echo "<p><strong>Name:</strong> $name</p>";
8     echo "<p><strong>Message:</strong> $message</p>";
9 }
10 ?>
11 <a href='contact.php'>Go Back</a>
12
```

using “htmlspecialchars()”

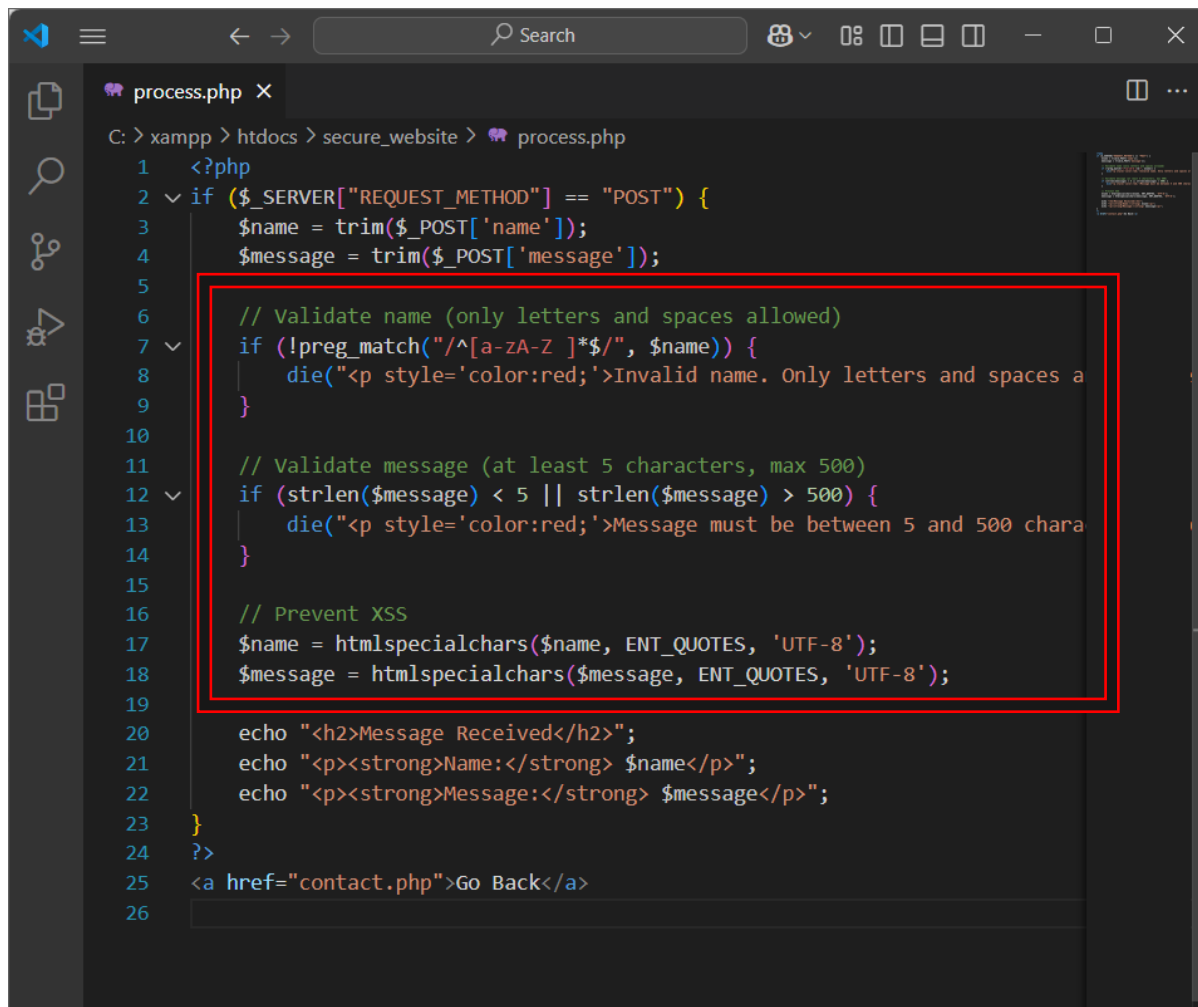
localhost/secure_website/process.php

Message Received

Name: <script>alert('Hacked!')</script>
Message: Hii
[Go Back](#)

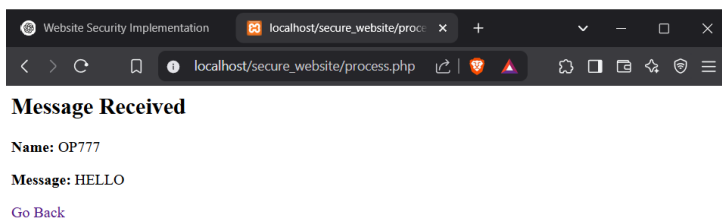
2. Implement Input Validation

Modify process.php to Validate Input



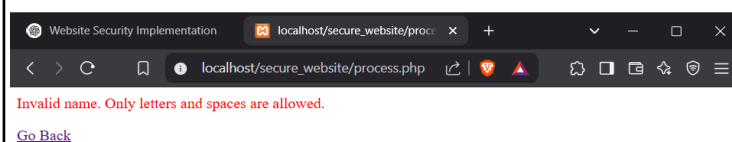
```
1 <?php
2 if ($_SERVER["REQUEST_METHOD"] == "POST") {
3     $name = trim($_POST['name']);
4     $message = trim($_POST['message']);
5
6     // Validate name (only letters and spaces allowed)
7     if (!preg_match("/^[a-zA-Z ]*$/", $name)) {
8         die("<p style='color:red;'>Invalid name. Only letters and spaces a
9     }
10
11    // Validate message (at least 5 characters, max 500)
12    if (strlen($message) < 5 || strlen($message) > 500) {
13        die("<p style='color:red;'>Message must be between 5 and 500 chara
14    }
15
16    // Prevent XSS
17    $name = htmlspecialchars($name, ENT_QUOTES, 'UTF-8');
18    $message = htmlspecialchars($message, ENT_QUOTES, 'UTF-8');
19
20    echo "<h2>Message Received</h2>";
21    echo "<p><strong>Name:</strong> $name</p>";
22    echo "<p><strong>Message:</strong> $message</p>";
23 }
24 ?>
25 <a href="contact.php">Go Back</a>
26
```

Before



Also accepting number and special characters in the name input

After



Showing invalid input when taking number and character in input

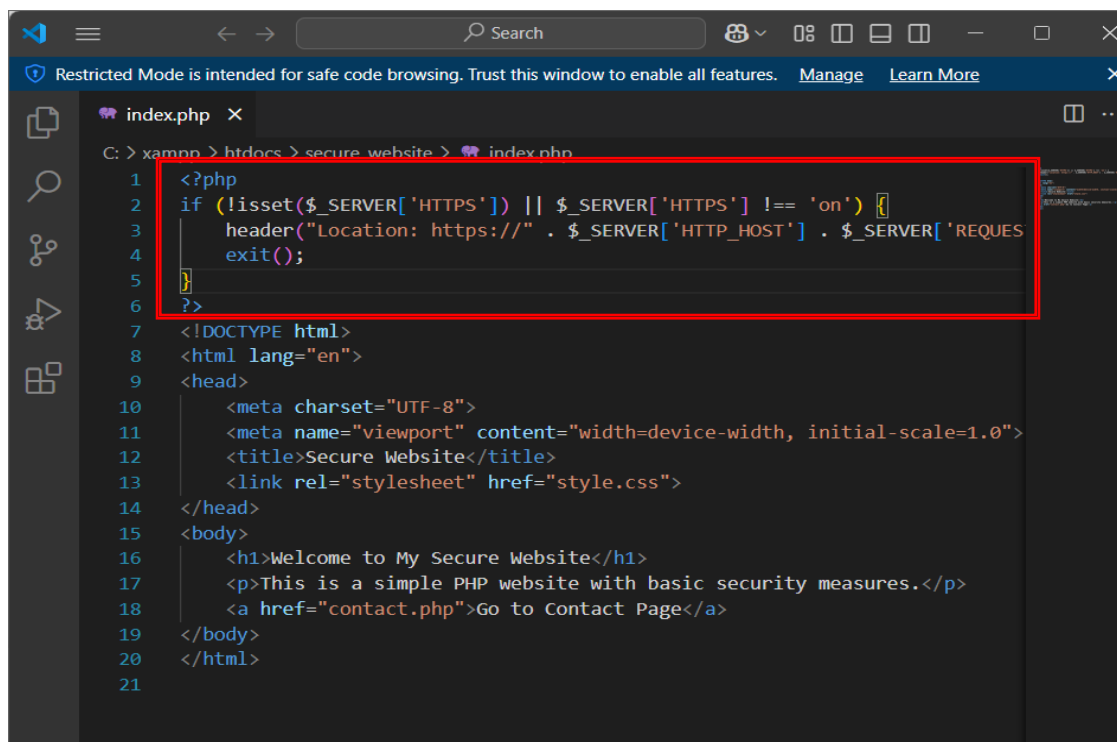
3. Enforce HTTPS

Creating “.htaccess” file in the website folder

And add the code

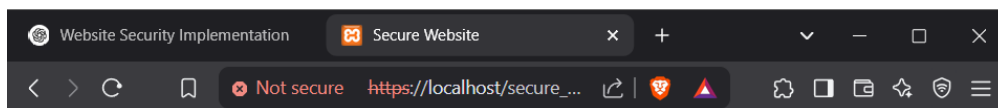
```
RewriteEngine On  
RewriteCond %{HTTPS}!=on  
RewriteRule ^(.*)$ https://%{HTTP_HOST}/$1 [R=301,L]
```

Modify index.php



```
1 <?php  
2 if (!isset($_SERVER['HTTPS']) || $_SERVER['HTTPS'] !== 'on') {  
3     header("Location: https://" . $_SERVER['HTTP_HOST'] . $_SERVER['REQUEST_URI']);  
4     exit();  
5 }  
6 ?>  
7 <!DOCTYPE html>  
8 <html lang="en">  
9 <head>  
10     <meta charset="UTF-8">  
11     <meta name="viewport" content="width=device-width, initial-scale=1.0">  
12     <title>Secure Website</title>  
13     <link rel="stylesheet" href="style.css">  
14 </head>  
15 <body>  
16     <h1>Welcome to My Secure Website</h1>  
17     <p>This is a simple PHP website with basic security measures.</p>  
18     <a href="contact.php">Go to Contact Page</a>  
19 </body>  
20 </html>  
21
```

Try opening your site with http



Welcome to My Secure Website

This is a simple PHP website with basic security measures.

[Go to Contact Page](#)

Its showing "**Not secure**" warning and "**https**" because localhost server doesn't have SSL certificate configured.